JWT | JSON Web Token

Authentication & API Security

WHAT IS JWT?

JWT is a token used to verify users and manage access to protected APIs.

THE 3 PARTS

01 HEADER

Contains the token type and signing algorithm.

02 PAYLOAD

Contains user information, roles, and expiration time.

03 SIGNATURE

Helps verify that the token has not been modified

Encoded token format: header.payload.signature

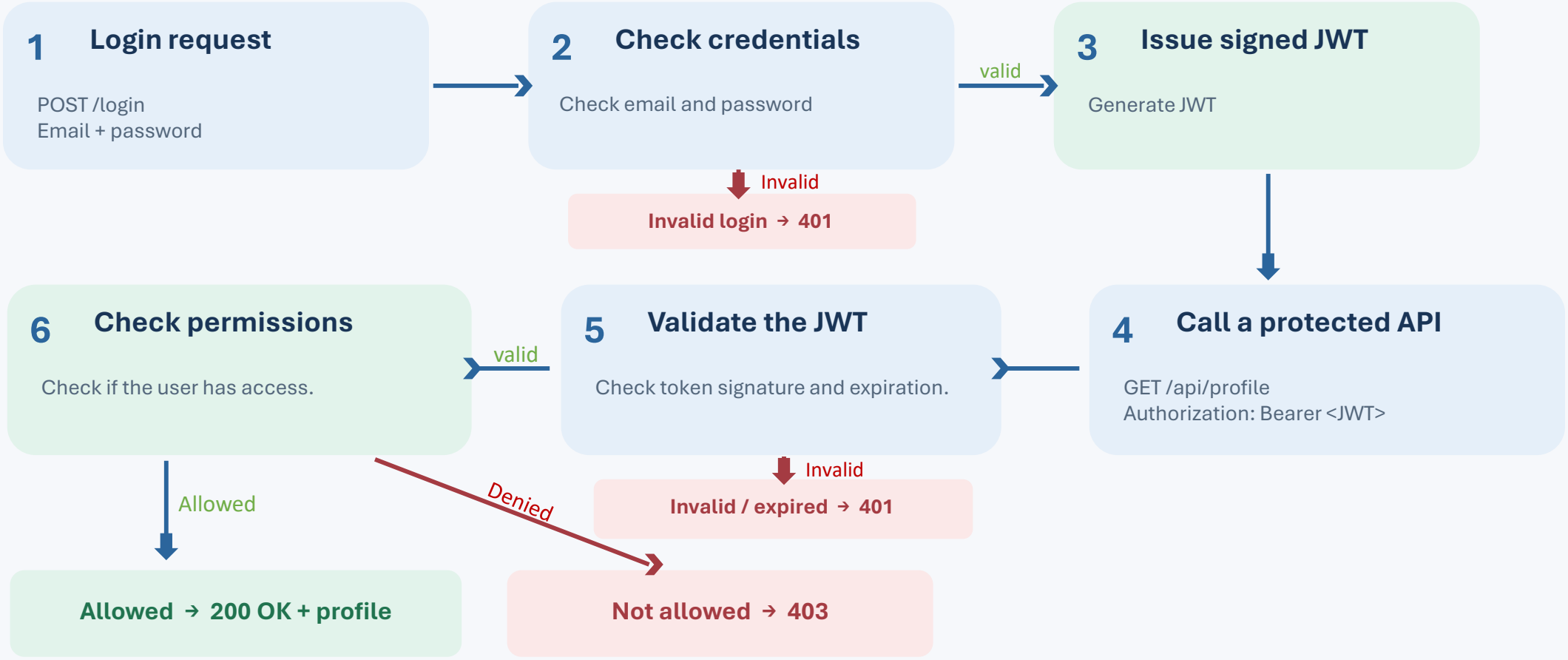
HOW IT WORKS

1 User logs in → 2 Server verifies credentials → 3 Server issues a signed JWT → 4 Client sends JWT with API request → 5 Server validates JWT and checks permissions

SECURITY NOTE JWT data can be decoded, so sensitive information should not be stored inside it.

JWT IN ACTION | A Login & API Request Example

SCENARIO: A user logs in and requests their profile.



KEY IDEA | JWT helps verify the user, but access still depends on their permissions.